词迹：安全修复与性能验证

2026-11-10 · 分支 work · 本地候选 · 未发布 · 应用版本 2.19.3

01 扫描与修复范围

最新 Codex Security 扫描于 11 月 10 日 05:20 UTC 完成，基线为 f10737e（2.19.2）。四项发现已修复并验证：2 项高风险、2 项中风险。

- 逐项检查原始触发、正常对照与同类入口。
- 自动日志追加覆盖听写中的私人原文。
- 兼容性安全与性能修复，版本升至 2.19.3。

02 问题与修复

问题	原因	修复
私有文件进入发布包 高风险	Git 忽略规则隐藏 .pem、.env 等文件；public 与迁移目录被递归打包。	打包前拒绝额外文件、敏感文件名和符号链接；从指定提交建立私有目录，按清单归档，并读回核对路径、类型、大小与摘要。
构建依赖来源未验证 高风险	直接执行工作区 node_modules 中的构建工具，未强制重装锁定依赖。	隔离目录先运行有时限的 npm ci，再构建和校验。原工作区的依赖树不进入发布链；任何步骤失败均停止归档。
生成内容冒充教材 中风险	对话仅检查 JSON 和文本长度，缺少结构化任务已有的教材声明校验。	复用服务端声明校验，覆盖正文和操作按钮；服务端生成来源信息，页面及恢复的历史明确显示“AI 生成内容 · 教材原文未核验”。
自动日志保存私人文本 中风险	口语、追问、个人文章与听写将自由文本或私人标识写入事件和每日摘要。	客户端与服务端共享结构化事实规则，屏蔽个人文章记录；迁移清理自动文本与派生摘要，保留主动编辑，清空日志时拦截迟到写入。

- 补查同类入口：听写标题可带入私人文章句子，已纳入共享日志规则；账号、临时会话与隐私版本隔离继续保留。
- 精简检索热路径：复用不可变词库的规范化来源信息，只收集有界排名结果，避免重复规范化和收集全部匹配结果。

03 性能（实际测量）

4,681 条词库；Node v24.22.1；同进程交替采样 15 轮，取中位数。暖索引每样本 100 次查询；冷索引每样本 1 次。

场景	修改前	修改后	
教材 + 单元（暖）	44.55 ms	33.03 ms	
宽泛文本查询（暖）	32.43 ms	26.17 ms	
跨教材单元查询（暖）	272.19 ms	68.03 ms	
首次教材查询（冷）	14.79 ms	15.32 ms	

107 组查询与基线完整输出一致。暖查询耗时下降 19.3%–75.0%；冷启动增加 0.53 ms。 浅灰为改前，炭黑为改后；每行使用同一比例。

扫描来源：Codex Security Cloud · 2026-11-10 05:20 UTC。
计时包含工具执行与结果序列化；不含模型、网络或浏览器渲染。原始数据：toolbox-benchmark.json。

界面与验证记录

2026-11-10 · 2.19.3 · 实际浏览器、行为回归与发布链验证

04 截图



桌面 1440 × 900 · 历史恢复后，生成标识保留；脚本文字按文本显示。



手机 390 × 844 · 触控布局，无横向溢出。

05 验证结果

检查	结果	实际覆盖
完整验收	684 / 684 通过	npm test：数据审计、类型、ESLint、全量测试、生产构建；本地 Worker / D1 55 项验证通过。单测 0 失败、0 跳过。
安全边界与复核	通过	恶意教材声明与正常页码对照；私人标记清理、SQL 迁移、清空竞争与旧请求拦截；独立复核完成。
浏览器交互	12 项 + 10 项断言	桌面/手机核心流程、历史来源标识、私人文章日志隔离；清空取消、陈旧版本拒绝与正常清空。
隔离发布包	552 个成员验证	全新安装 513 个依赖；760 个源码/构建输入一致，552 个归档成员读回通过。私有文件被拒绝，诱饵依赖未执行，迁移副本一致。
生产依赖审计	0 个已知漏洞	npm run audit:prod，读取 npm 官方漏洞公告；本次未升级依赖。

06 交付与剩余事项

- 本地候选及验证包已生成；共享分支尚未提交、发布，Cloud 原扫描状态未关闭。迁移 0010 尚未应用到生产数据。
- 浏览器对话、记忆与日志使用受控接口；未调用付费模型。生产网关、真实服务商及物理设备仍需部署后验证。
- 现有词库内容缺口保持原状：333 个英文释义、153 个音标及 7 个含未解析记录的单元。

```
npm test · npm run audit:prod · bash scripts/package-site.sh
node --import ./tests/register.mjs scripts/benchmark-toolbox.mjs
node artifacts/qa/security-20261110/browser-check.mjs
```

主要改动：scripts/package-site.sh、lib/assistant/core.ts 与 chat-core.ts、lib/learning-journal/、drizzle/0010。分项命令、结果与改动路径见 verification.json；测量和截图位于同目录。